ENTERPRISE SECURITY ENGINEERING SPECIFICATION
Title: Zero-Trust API Gateway Architecture & Threat Mitigation
Classification: Confidential Technical Blueprint

1. AUTHENTICATION & TOKEN LIFECYCLE

- All ingress traffic terminates at Envoy API Gateways enforcing TLS 1.3 with strict Forward Secrecy cipher suites.
- Identity is verified via ephemeral RS256/HS256 JWT tokens with a maximum lifespan of 24 hours.
- Token revocation is enforced across distributed nodes using token-fingerprint blacklists.

2. RATE LIMITING & DOS MITIGATION

- Public Endpoints (/auth/login): 5 requests per minute per IP using token-bucket rate limiters.
- Authenticated Ingestion (/documents/upload): 50 requests per hour per user account.
- Payload Body Size Limit: Strict 25 MB ceiling enforced at NGINX reverse proxy buffer.

3. DATABASE CONNECTION RESILIENCE

- Asyncpg connection pooling: Minimum 5 connections, maximum 20 connections per serverless worker.
- Pool pre-ping (`pool_pre_ping=True`) verifies socket health before query execution to eliminate stale socket crashes.